Báo cáo tích hợp — Đặc tả → Kripke → Sinh mã → CWE/CVE

Đặc tả: smartlab_access_controller

Mục lục

1. Đặc tả yêu cầu (Specification) 2

2. Kiểm chứng hình thức (Kripke/CTL) 3

2.1. Sơ đồ chuyển trạng thái 4

3. Mã C sinh ra & Static Checker (lỗi bộ nhớ) 4

4. Trích xuất AST/điều kiện & SMT (Z3) 5

5. Dynamic Fuzzing (hàm Python sinh ra) 6

6. Phân loại CWE/CVE tổng hợp 7

7. Test case truy vết từ đặc tả (tài liệu hóa) 8

1. Đặc tả yêu cầu (Specification)

Bộ điều khiển mở cửa SmartLab xác thực thẻ và mã mở khóa khẩn cấp. Access worker và audit worker dùng chung access_guard; hệ thống ghi nhận sự kiện truy cập và dùng các fixture lỗi có chủ đích cho thực hành.

Mã yêu cầu	Loại	Ưu tiên	Nội dung
REQ-1	safety	HIGH	Access worker và audit worker không được đồng thời giữ access_guard.
REQ-2	liveness	HIGH	Cụm access_guard không được deadlock khi hai worker tranh chấp khóa.
REQ-3	liveness	HIGH	Một phiên xét duyệt thông thường phải hoàn tất sau khi cấp quyền hoặc từ chối.
REQ-4	memory	HIGH	Hàm phân tích mã thẻ không được sao chép quá bộ đệm 20 ký tự ASCII.
REQ-5	memory	MEDIUM	Hàm tạo audit record phải giải phóng vùng nhớ đã cấp phát.
REQ-6	memory	HIGH	Hàm đóng phiên không được giải phóng cùng một con trỏ nhiều hơn một lần.
REQ-7	memory	HIGH	Hàm xóa badge cache không được truy cập vùng nhớ sau khi giải phóng.
REQ-8	safety	MEDIUM	Bộ đếm sự kiện truy cập không được tràn int32 khi cộng các bộ đếm đầu vào.
REQ-9	functional	MEDIUM	Hàm tỷ lệ truy cập hợp lệ phải xử lý mẫu số bằng 0 có kiểm soát.
REQ-10	functional	HIGH	Mã mở cửa khẩn cấp gồm hai số nguyên 16-bit phải được kiểm thử bằng black-box và concolic fuzzing.
NFR-1	non_functional	HIGH	Pipeline phải hoàn thành 300 vòng fuzzing black-box trong không quá 30 giây trên máy thực hiện bài.

Mã yêu cầu	Loại	Ưu tiên	Nội dung
NFR-2	non_functional	HIGH	Mỗi phép chạy fuzzing phải lưu seed, số vòng lặp, thời gian chạy và input gây lỗi hoặc đạt nhánh đích.
NFR-3	non_functional	HIGH	Báo cáo kết quả phải tái lập được trong 5 lần chạy với seed đã công bố.
NFR-4	non_functional	HIGH	Log kết quả phải phân biệt rõ lỗi cố ý của mã sinh cho thực hành và hành vi nghiệp vụ mong muốn của SLAC.
NFR-5	non_functional	MEDIUM	Tài liệu hướng dẫn chạy lại phải cho phép thành viên còn lại tạo cùng report mà không cần chỉnh mã nguồn.
CON-1	constraint	HIGH	Đặc tả phải dùng đúng 10 sheet và đúng tên sheet theo template Spec Verification Lab.
CON-2	constraint	HIGH	Mã thẻ phòng lab dài tối đa 20 ký tự ASCII; giá trị này phải khớp KichThuocBuffer của hàm parse_badge_code.
CON-3	constraint	HIGH	Mã mở cửa khẩn cấp là cặp số nguyên không dấu 16-bit.
CON-4	constraint	HIGH	Tool được chạy trên bản sao Excel của nhóm; template gốc của giảng viên luôn giữ nguyên.
CON-5	constraint	HIGH	Không dùng secret, API key, dữ liệu cá nhân thật hoặc kết nối thiết bị thật trong bất kỳ test nào.

2. Kiểm chứng hình thức (Kripke/CTL)

Trạng thái deadlock: không có

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!violation)	VI PHẠM	access_denied, access_granted, credential_review, entry_idle, override_review, session_closed
EF(access_locked)	ĐÚNG	access_conflict, access_free, access_holds, audit_holds
AF(complete)	ĐÚNG	access_conflict, access_denied, access_free, access_granted, access_holds, audit_holds, credential_review, entry_idle, override_review, session_closed

Mutual exclusion: VI PHẠM (trạng thái nguy hiểm: access_conflict, access_free, access_holds, audit_holds)

2.1. Sơ đồ chuyển trạng thái

Sơ đồ: Mô hình chính: smartlab_access_controller

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% Mô hình chính: smartlab_access_controller
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=gray!15] (nd_access_granted) at (-0.56,1.92) {access\_granted\\{\tiny door\_unlocked}};
\node[fill=gray!15] (nd_credential_review) at (1.41,0.92) {credential\_review\\{\tiny normal\_entry\_active}};
\node[fill=gray!15] (nd_entry_idle) at (0.23,-0.08) {entry\_idle\\{\tiny door\_locked,entry\_ready}};
\node[fill=gray!15] (nd_session_closed) at (-2.07,0.80) {session\_closed\\{\tiny complete}};
\node[fill=gray!15] (nd_override_review) at (0.95,1.57) {override\_review\\{\tiny override\_entry\_active}};
\node[fill=gray!15] (nd_access_holds) at (-0.32,0.06) {access\_holds\\{\tiny access\_locked}};
\node[fill=gray!15] (nd_access_denied) at (0.50,-0.09) {access\_denied\\{\tiny door\_locked}};
\node[fill=gray!15] (nd_audit_holds) at (-0.21,-2.20) {audit\_holds\\{\tiny audit\_locked}};
\node[fill=blue!25] (nd_access_free) at (-1.05,-1.05) {access\_free\\{\tiny safe}};
\node[fill=red!35] (nd_access_conflict) at (1.12,-1.86) {access\_conflict\\{\tiny access\_locked,audit\_locked,violation}};
\draw (nd_access_granted) -- (nd_session_closed);
\draw (nd_credential_review) -- (nd_access_denied);
\draw (nd_credential_review) -- (nd_access_granted);
\draw (nd_entry_idle) -- (nd_override_review);
\draw (nd_entry_idle) -- (nd_credential_review);
\draw (nd_session_closed) -- (nd_session_closed);
\draw (nd_override_review) -- (nd_access_denied);
\draw (nd_override_review) -- (nd_access_granted);
\draw (nd_access_holds) -- (nd_access_conflict);
\draw (nd_access_denied) -- (nd_session_closed);
\draw (nd_audit_holds) -- (nd_access_conflict);
\draw (nd_access_free) -- (nd_access_holds);
\draw (nd_access_free) -- (nd_audit_holds);
\draw (nd_access_free) -- (nd_entry_idle);
\draw (nd_access_conflict) -- (nd_entry_idle);
\end{tikzpicture}
```

3. Mã C sinh ra & Static Checker (lỗi bộ nhớ)

Mã C sinh từ đặc tả

```
#include <stdio.h>
#include <stdlib.h>
```

```
#include <string.h>

/* sinh từ đặc tả 'smartlab_access_controller', hàm 'parse_badge_code', kind='buffer_copy' */
void parse_badge_code(const char *raw_badge) {
char buffer[20];
strcpy(buffer, raw_badge); /* sinh từ đặc tả: buffer-overflow */
printf("%s\n", buffer);
}

/* sinh từ đặc tả 'smartlab_access_controller', hàm 'create_audit_record', kind='alloc_release' */
void create_audit_record(void) {
int *buf = malloc(sizeof(int) * 32);
buf[0] = 0;
/* sinh từ đặc tả: memory-leak (thiếu free) */
}

/* sinh từ đặc tả 'smartlab_access_controller', hàm 'close_access_session', kind='alloc_release' */
void close_access_session(void) {
int *buf = malloc(sizeof(int) * 8);
buf[0] = 0;
free(buf);
free(buf); /* sinh từ đặc tả: double-free */
}

/* sinh từ đặc tả 'smartlab_access_controller', hàm 'reset_badge_cache', kind='alloc_release' */
void reset_badge_cache(void) {
int *buf = malloc(sizeof(int) * 16);
buf[0] = 0;
free(buf);
buf[0] = 1; /* sinh từ đặc tả: use-after-free */
}

/* sinh từ đặc tả 'smartlab_access_controller', hàm 'access_event_total', kind='arithmetic' */
int access_event_total(int granted_events, int pending_events) {
return granted_events + pending_events;
}
```

Dòng	Mức độ	Loại lỗi	Mô tả
8	HIGH	dangerous-function	Sử dụng hàm không an toàn 'strcpy()' — dễ gây buffer overflow. Goi y: dung strncpy thay the.
14	MEDIUM	memory-leak	Con trỏ 'buf' được cấp phát (malloc/calloc/realloc) nhưng không thấy free() trong hàm create_audit_record() — nghi ngờ rò rỉ bộ nhớ
24	HIGH	double-free	Double-free trên con trỏ 'buf' (đã free() tại dòng 23) trong hàm close_access_session()
32	HIGH	use-after-free	Khả năng sử dụng con trỏ 'buf' sau khi free() (freed tại dòng 31) trong hàm reset_badge_cache()

4. Trích xuất AST/điều kiện & SMT (Z3)

Hàm	Biến	Điều kiện	Vòng lặp	Độ phức tạp McCabe	Độ sâu lồng nhau
parse_badge_code	['buffer']	[]	[]	1	1
create_audit_record	['buf']	[]	[]	1	1
close_access_session	['buf']	[]	[]	1	1
reset_badge_cache	['buf']	[]	[]	1	1
access_event_total	[]	[]	[]	1	1
valid_access_ratio	[]	[]	[]	1	1
unlock_override_code	[]	['override_a == 5813', 'override_b == 2649']	[]	3	3

Kiểm tra	Kết quả SMT	Model (nếu SAT)
access_event_total	sat	{'granted_events': 2000000001, 'pending_events': 0}
access_event_total (int32 overflow?)	sat	{'granted_events': -1, 'pending_events': -2147483648}
audit_byte_total	sat	{'written_bytes': 2000000001, 'buffered_bytes': 0}
audit_byte_total (int32 overflow?)	sat	{'written_bytes': -1, 'buffered_bytes': -2147483648}
daily_badge_total	sat	{'accepted_today': 32768, 'queued_today': 0}
daily_badge_total (int32 overflow?)	sat	{'accepted_today': -1, 'queued_today': -2147483648}
active_session_total	sat	{'active_sessions': 65536, 'closing_sessions': 0}
active_session_total (int32 overflow?)	sat	{'active_sessions': -1, 'closing_sessions': -2147483648}
denied_attempt_total	sat	{'denied_today': 32768, 'delayed_denials': 0}
denied_attempt_total (int32 overflow?)	sat	{'denied_today': 1, 'delayed_denials': 2147483647}

5. Dynamic Fuzzing (hàm Python sinh ra)

Hàm Python 'valid_access_ratio'

```
def valid_access_ratio(granted, attempted):
return granted // attempted
```

Hàm Python 'unlock_override_code'

```
def unlock_override_code(override_a, override_b):
```

```
if override_a == 5813:
if override_b == 2649:
raise ValueError('magic value reached')
return override_a + override_b
```

Hàm	Kết quả fuzzing
valid_access_ratio	black-box: 11/300 lan crash
unlock_override_code	concolic: crash_input={'override_a': 5813, 'override_b': 2649} sau 3 lan thu

6. Phân loại CWE/CVE tổng hợp

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(!violation)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	mô hình trạng thái	mutual-exclusion-violation	CWE-667 — Improper Locking	-
ch2	dong 8	dangerous-function	CWE-120 — Buffer Copy without Checking Size of Input	CVE-2003-0352 (2003)
ch2	dong 14	memory-leak	CWE-401 — Missing Release of Memory after Effective Lifetime	-
ch2	dong 24	double-free	CWE-415 — Double Free	-
ch2	dong 32	use-after-free	CWE-416 — Use After Free	CVE-2019-0708 (2019)
ch3	access_event_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	audit_byte_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	daily_badge_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch3	active_session_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	denied_attempt_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch4	valid_access_ratio	uncontrolled-crash	CWE-248 — Uncaught Exception	-
ch4	unlock_override_code	uncontrolled-crash	CWE-248 — Uncaught Exception	-

7. Test case truy vết từ đặc tả (tài liệu hóa)

ID	Ưu tiên	Tiêu đề	Truy vết yêu cầu	Kết quả mong đợi
TC-1	HIGH	Cụm khóa access_guard cố ý có xung đột	REQ-1, REQ-2	AG(!violation) vi phạm và mutex phát hiện trạng thái nguy hiểm có chủ đích
TC-2	HIGH	Vòng đời một phiên xét duyệt	REQ-3	AF(complete) đúng từ trạng thái khởi tạo
TC-3	HIGH	Mã thẻ dài hơn 20 ký tự	REQ-4, CON-2	Phát hiện dangerous-function (CWE-120) trên test fixture
TC-4	HIGH	Vòng đời bộ nhớ audit và phiên	REQ-5, REQ-6, REQ-7	Phát hiện CWE-401, CWE-415 và CWE-416 trên fixture
TC-5	MEDIUM	Bộ đếm sự kiện vượt ngưỡng int32	REQ-8	SAT: tồn tại đầu vào có thể tràn số
TC-6	MEDIUM	Mẫu số tỷ lệ truy cập bằng 0	REQ-9	Có ít nhất một ZeroDivisionError trên fixture
TC-7	HIGH	Tìm mã mở cửa khẩn cấp	REQ-10, CON-3	Tìm đúng cặp và đạt nhánh test oracle
TC-8	HIGH	So sánh fuzzing trên target của nhóm	REQ-10, NFR-1, NFR-2, NFR-3	Bảng có mean, median, thời gian và input đạt đích